

Clase 10

8 de junio
2026

Certificación CISSP

<https://www.isc2.org/certifications/cissp>

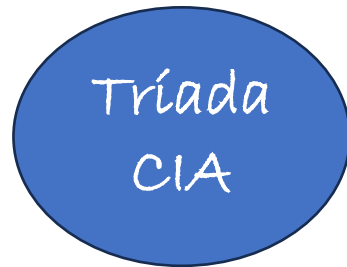
Certified Information System Security Professional

Domínios de conocimiento:

1. Gestión de Seguridad y riesgos
2. Seguridad de activos
3. Arquitectura e ingeniería de la seguridad
4. Seguridad de comunicaciones y redes
5. Gestión de identidades y accesos (IAM)
6. Evaluación y pruebas de seguridad
7. Operaciones de seguridad
8. Seguridad del desarrollo de software

Seguridad Informática

→ preservar



Confidencialidad

Guardar info en secreto
(Acceso a autorizados)

Integridad

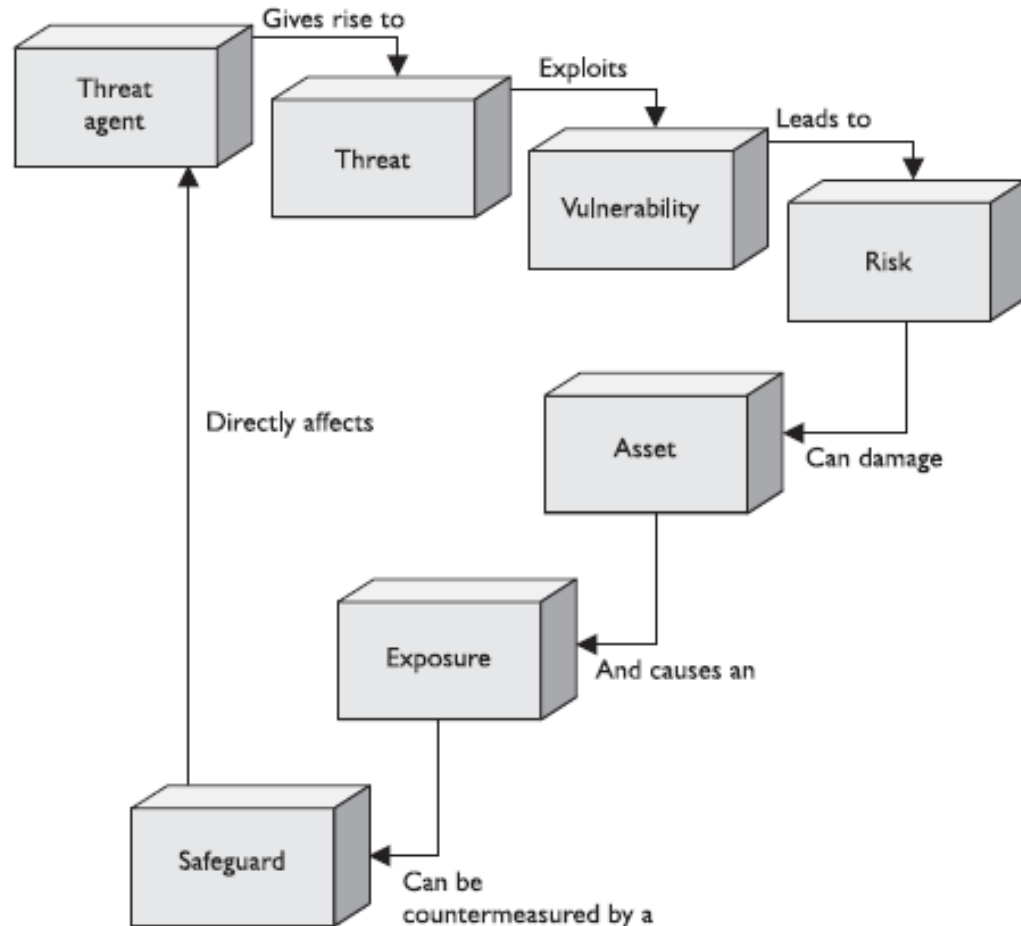
confiabilidad

- Integridad de datos
- Integridad de origen

Disponibilidad

Poder usar la info

Definiciones de seguridad



Amenaza: Peligro potencial asociado a la explotación de una vulnerabilidad.

Vulnerabilidad: Falta o debilidad en una medida implementada.

Riesgo: Probabilidad de que un agente explote la vulnerabilidad y produzca efectos en el negocio

Exposición: Exposición a pérdidas

Medidas: Mecanismos para reducir el riesgo. Control.

Típos de control

Administrativos

Técnicos (lógicos)

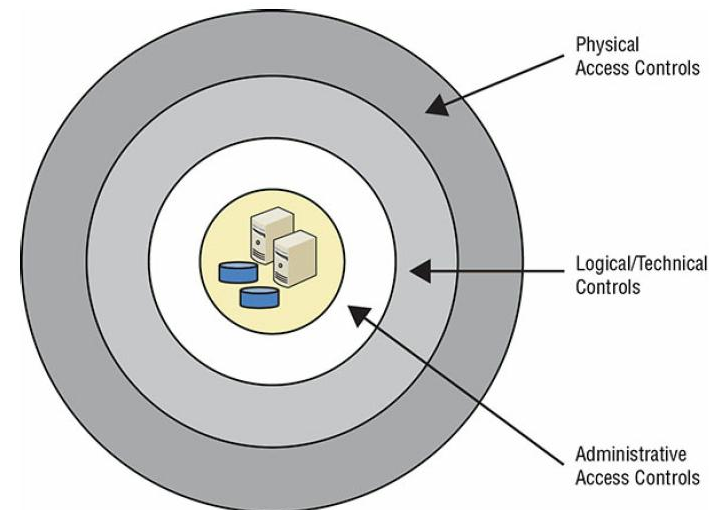
Físicos

Defensa en profundidad

Uso coordinado de múltiples controles en un enfoque por capas.

=> Minimiza riesgos.

(Cada capa protege a la siguiente y en el centro: Activos críticos).



Políticas Mecanismos

Qué acciones son seguras (permitidas) y qué acciones son inseguras (prohibidas)

Procedimiento, herramienta o método para garantizar cumplimiento de política

Prevenir

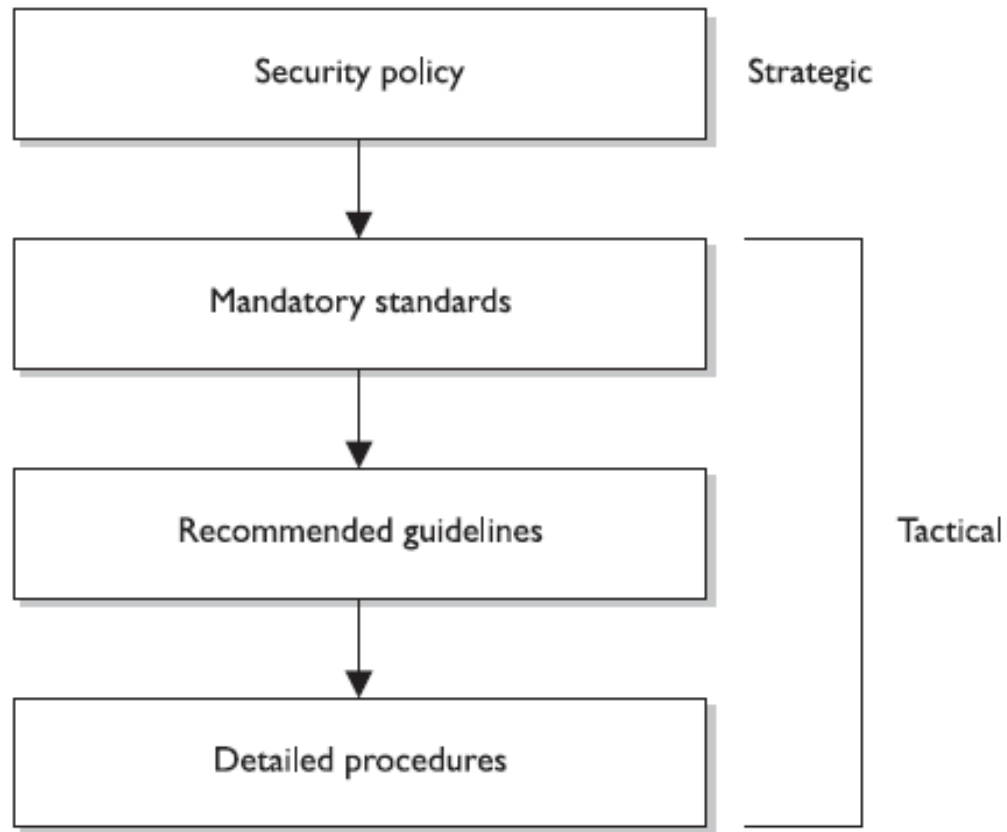
Detectar

Recuperar

Dísuadir

Corregir Compensar

Políticas, estándares, guías, procedimientos



Estándares: Reglas obligatorias de seguridad que el hardware y el software deben cumplir.

Guías (directrices): Acciones recomendadas, directrices operaciones destinadas a usuarios y personal para cuando no puede aplicarse un estándar específico.

Procedimientos: Tareas detalladas paso a paso que deberían cumplirse para lograr algún objetivo.

Estándares de NIST

(National Institute of Standards and Technology)

NIST 800-53: Obligatorio para sistemas de información federal

NIST CSF 2.0: (Cybersecurity framework) voluntario para las organizaciones.
Basado en riesgos. Más flexible y adaptable.



Gobernanza: cómo se gestiona la organización

Gobernanza de seguridad: cómo se gestiona la seguridad a través de políticas y procedimientos.

NIST SP 800-207 ZTA=Zero Trust Architecture

Ideas:

1. Never Trust
2. Always Verify
3. Assume breach

Gestión de seguridad

La gestión de seguridad se focaliza en la protección continua de activos y recursos de la organización.

Incluye:

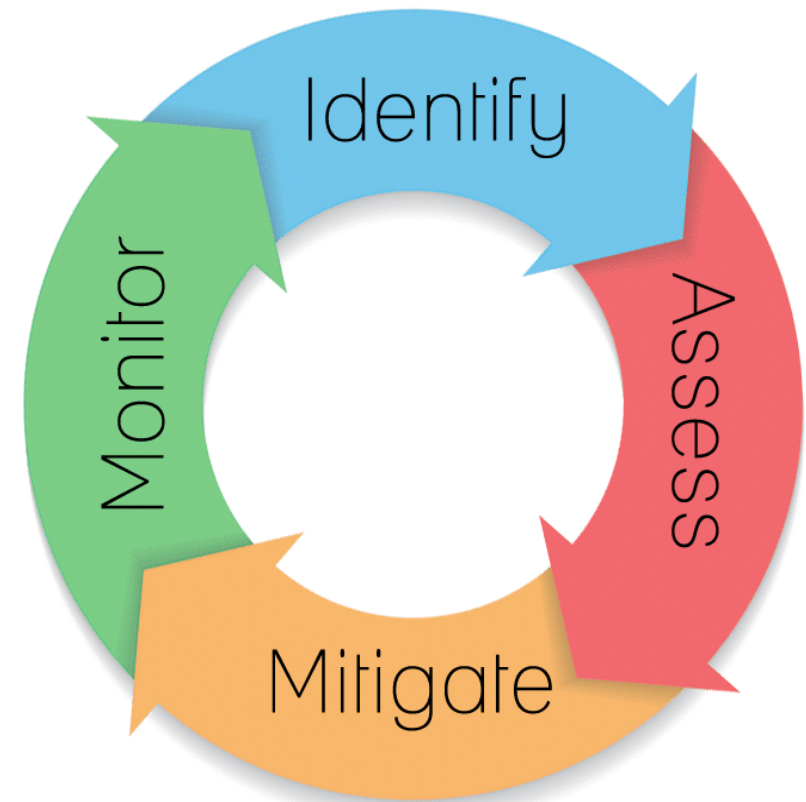
- Gestión de Riesgos
- Documentación
- Implementación de controles de seguridad.
- Procesos y procedimientos.
- Personal de seguridad.
- Auditoría.

Gestión de riesgos

Proceso de:

- Identificar activos críticos p/negocio.
- Evaluar impacto en negocio.
- Reducir a nivel aceptable.
- Monitorear para mantener nivel.

Calcular riesgo de amenaza y relacionarlo con los intereses de negocio.



Mecanismos de protección

Categorización de Amenazas: STRIDE

Spoofing: Suplantación de identidad

Tampering: Manipulación, alteración.

Repudiation: Repudio

Information disclosure: Revelación de información

Denial of Service: Denegación de servicios

Elevation of privilege: Elevación de privilegios.

Mecanismos de protección

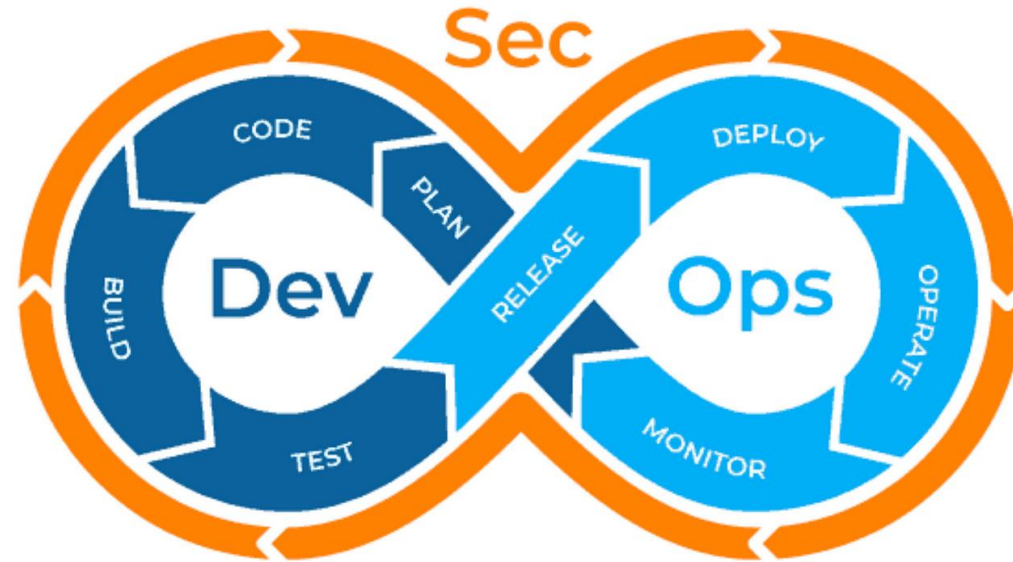
Cada amenaza debe abordarse y planificarse individualmente:

- Control de acceso
- Arquitectura y diseño de sistema.
- Desarrollo del software
- Entorno y seguridad física.
- Redes y telecomunicaciones
- Etc.

Diferentes metodologías: DevSecOps, DAST, CSPM, etc.

DevSecOps = Development + Security + Operations

Metodología que integra la seguridad en los procesos de desarrollo de software y operaciones de tecnología de la información.



DAST y SCA

Metodologías de testeo de seguridad de las aplicaciones.

DAST = Dynamic Application Security Testing
Evalúa aplicación mientras se ejecuta.

SAST = Static Application Security Testing
Evalúa aplicación analizando el código.

SCA = Software Composition Analysis

SBOM

Inventario formal de componentes de software y dependencias y la Metodología de su realización.

SBOM = Software Bill of Materials.

Protección en la nube

Metodologías de gestión de la protección en la nube

CSPM = Cloud Security Posture Management

Busca problemas de configuración y permisos.

CWSS = Cloud Workflow Protection Platform

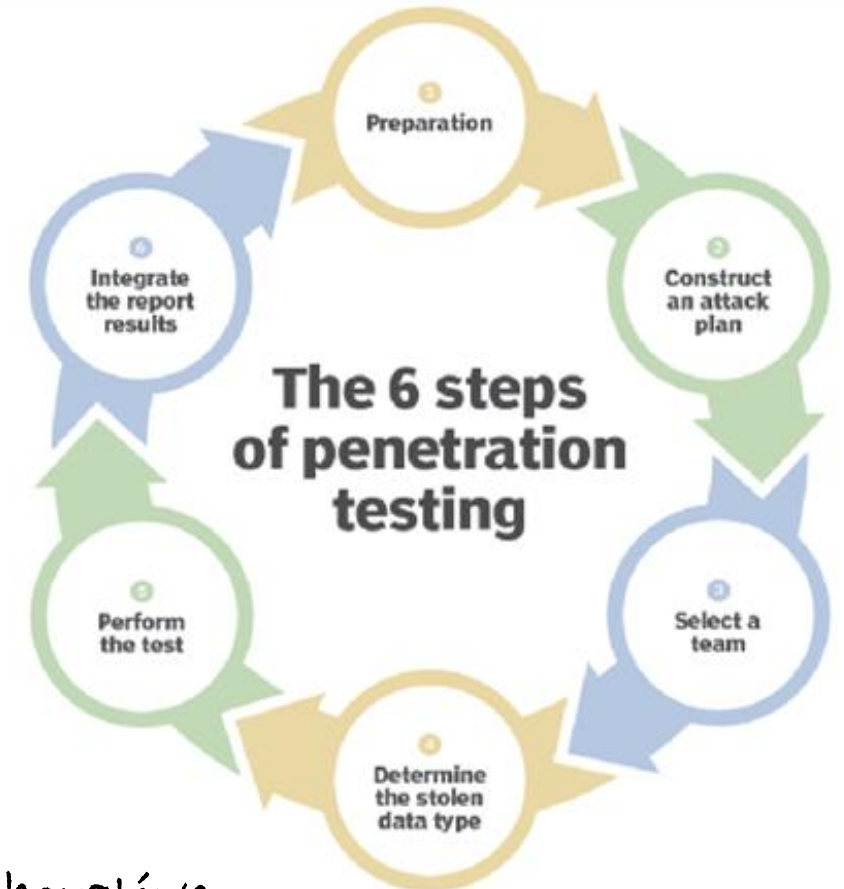
Protección de aplicaciones corriendo en la nube.

CIEM = Cloud Infrastructure Entitlement Management

Foco en los permisos de sujetos en recursos en la nube.

Evaluación de la seguridad

- Evaluación de riesgos.
- Evaluación de seguridad física, de aplicaciones (vulnerabilidades)
- Pruebas de penetración (Pentesting) → más exhaustiva
- Auditorías de seguridad → revisión sistemática de las políticas.
- Evaluación de cumplimiento → de estándares.
- Red/Blue/Purple Team = ofensiva, defensiva, colaborativa
- BAS (breach + attack Simulation)



Ejemplo: Atos en [JJOO Paris](#)